UNITE D'ETUDE DEUX : MISSIONS D'ASSURANCE ET DE CONFORMITE

Cette unité d'étude est la deuxième des quatre couvrant le **domaine I : Gestion de l'activité d'audit interne** du Syllabus des examens de la CIA de l'IIA. Ce domaine représente 20% de la partie 2 de l'examen CIA et est testé aux niveaux cognitif de **base** et **compétent**. La partie pertinente du programme est mise en évidence ci-dessous. (Le programme complet se trouve à l'annexe B.)

	Gestion de l'activité d'audit interne (20%)		
	1 . Opérations d'audit interne		
	A	Décrire les politiques et les procédures de planification, d'organisation, de direction et de suivi des opérations d'audit interne	De base
	B	Interpréter les activités administratives (budgétisation, ressources, recrutement, dotation, etc.) de l'activité d'audit interne	De base
	2 . Etablir un plan d'audit interne fondé sur les risques		
	A	Identifier les sources de missions potentielles (univers d'audit, exigences du cycle d'audit, demandes de la direction, mandats réglementaires, tendances du marché et du secteur, questions émergentes, etc.)	De base
	B	Identifier un cadre de gestion des risques pour évaluer les risques et hiérarchiser les missions d'audit en fonction des résultats d'une évaluation des risques	De base
	C	**Interpréter les types de missions d'assurance (évaluations des risques et des contrôles, audits de tiers et de conformité des contrats, sécurité et confidentialité, audits de performance et de qualité, indicateurs clés de performance, audits opérationnels, audits de conformité financière et réglementaire)**	**Compétences**
I	D	Interpréter les types de missions de conseil (formation, conception de systèmes, développement de systèmes, diligence raisonnable, respect de la vie privée, analyse comparative, évaluation du contrôle interne, cartographie des processus, etc.	Compétences
	E	Décrire la coordination des efforts d'audit interne avec l'auditeur externe, les organismes de contrôle réglementaire et les autres fonctions d'assurance interne, ainsi que la dépendance potentielle à l'égard d'autres fournisseurs d'assurance	De base
	3. Communication et rapports à l'encadrement supérieur et au conseil d'administration		
	A	reconnaître que le responsable de l'audit communique le plan d'audit annuel à la direction générale et au conseil d'administration et demande l'approbation de ce dernier	De base
	B	Identifier les risques importants et les problèmes de contrôle et de gouvernance dont le responsable de l'audit interne doit rendre compte au conseil d'administration	De base
	C	reconnaître que le responsable de l'audit interne rend compte de l'efficacité globale des processus de contrôle interne et de gestion des risques de l'organisation à la direction générale et au conseil d'administration	De base
	D	Reconnaître les indicateurs clés de performance de l'audit interne que le responsable de l'audit interne communique périodiquement à la direction générale et au conseil d'administration	De base

I. MISSIONS D'ASSURANCE

1. Audit financier, de conformités, opérationnelles et informatiques

Selon l'introduction aux normes, « les services d'assurance impliquent l'évaluation objective de la preuve par l'auditeur interne pour fournir une opinion indépendante ou des conclusions concernant une entité, une opération, une fonction, un processus, un système ou tout autre objet ».

Les **services d'assurance** sont « un examen objectif de la preuve dans le but de fournir une évaluation indépendante de la gouvernance, de la gestion des risques et des processus de contrôle pour l'organisation. Les exemples peuvent inclure des missions financières, de performance, de conformité, de sécurité du système et de due diligence « (Glossaire de l'IIA).

L'aperçu suivant des services d'assurance repose sur diverses publications de l'IIA :

L'assurance financière fournit une analyse de l'activité économique d'une entité mesurée et déclarée selon les méthodes comptables. **L'audit financier** examine le passé pour déterminer si les informations financières ont été correctement enregistrées et suffisamment prises en charge. Il évalue également si les affirmations des états financiers concernant les performances passées sont justes, précises et fiables.

L'assurance de conformité est l'examen des contrôles financiers et d'exploitation afin d'évaluer la conformité aux lois, normes, règlements, politiques, plans, procédures, contrats et autres exigences établis. **L'audit de conformité** examine le passé et le présent pour poser des questions comme suit :

- Avons-nous adhéré aux lois et aux règlements ?
- Respectons-nous actuellement les exigences légales et réglementaires ?
- Quelles sont les normes commerciales de notre organisation ?
- Tous les membres de notre personnel et notre équipe de direction respectent-ils constamment les politiques et procédures internes ?

L'assurance opérationnelle est l'examen d'une fonction ou d'un processus pour évaluer l'efficacité et l'économie des opérations et l'efficience avec laquelle ces fonctions atteignent leurs objectifs. **L'audit opérationnel** se concentre sur le présent et l'avenir. Il est étroitement aligné sur la mission, la vision et les objectifs de l'organisation. Il évalue également l'efficacité (s'assurer que les bonnes choses sont faites), l'efficience (s'assurer que les choses se font correctement) et l'économie (assurer la rentabilité) des opérations. Cette mentalité comprend des domaines tels que (1) qualité du produit, (2) service à la clientèle, (3) maximisation des revenus, (4) minimisation des dépenses, (5) prévention de la fraude, (6) sauvegarde des actifs, (7) la responsabilité sociale des entreprises et la citoyenneté, (8) des flux de travail rationalisés, (9) la sécurité et (10) la planification. Il se concentre sur ce qui fonctionne et ce qui n'est pas aussi bien que les possibilités d'amélioration future.

L'assurance informatique est l'examen et l'évaluation des TI (par exemple, les ordinateurs, l'infrastructure technologique, la gouvernance informatique, les appareils mobiles et le cloud

computing) pour assurer l'intégrité de l'information. Traditionnellement, **l'audit informatique** a été effectué dans des projets distincts par des spécialistes de l'audit informatique, mais de plus en plus, il est intégré à tous les audits.

Les trois catégories distinctes de services d'assurance correspondent aux trois objectifs de contrôle interne définis dans le cadre de contrôle (COSO).

Le **contrôle interne** est un processus effectué par le conseil, la direction et le personnel d'une entité qui est conçu pour fournir une assurance raisonnable quant à la réalisation des objectifs suivants :

- Les **objectifs opérationnels** ont trait à l'efficacité et l'efficience des opérations, par exemple, la réalisation des objectifs de performance opérationnelle et financière et la protection des actifs contre les pertes.
- Les **objectifs de conformité** concernent les rapports financiers et non financiers internes et externes et peuvent inclure la fiabilité, la rapidité et la transparence de ces rapports.
- Les **objectifs de conformité** concernent la conformité aux lois et réglementations applicables.

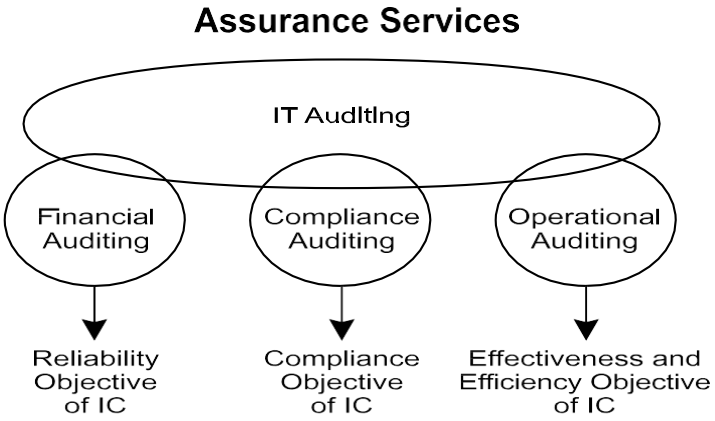

Figure 3-1

Les services décrits peuvent également être effectués par des auditeurs externes, par exemple dans des contrats de sous-traitance ou de co-sourcing. Néanmoins, l'attention traditionnelle des auditeurs externes repose sur la présentation fidèle des informations financières générales. En revanche, l'objectif traditionnel des auditeurs internes est de soutenir les autorités de gestion et de gouvernance dans l'exercice de leurs fonctions.

2. Cartographie de l'assurance

Une carte d'assurance est une représentation visuelle des risques et des activités d'assurance d'une organisation. Une carte d'assurance peut inclure les éléments suivants :

- Identité des prestataires d'assurance
- Le risque
- Niveau d'assurance
- Urgence ou importance de la question

- Action à prendre

Les prestataires d'assurance sont des parties prenantes internes et externes responsables de la mise en œuvre ou de la maintenance des services d'assurance. La direction fournit une assurance en se conformant aux lois et réglementations, en assurance qualité et en auto-évaluations. Le conseil d'administration fournit des assurances par le biais de la fonction d'audit interne. Les parties prenantes externes fournissent une assurance par l'intermédiaire de l'auditeur externe indépendant, des régulateurs gouvernementaux et des associations professionnelles telles que l'ISO.

Le risque est déterminé en évaluant le risque inhérent de l'activité, le risque que les contrôles internes ne puissent empêcher ou détecter le non-respect, et les conséquences potentielles du non-respect. Le niveau d'assurance est déterminé en prenant en compte la qualité, l'étendue et les coûts des contrôles internes. Plus le risque ou l'assurance est élevé, plus le problème est urgent ou important.

Les mesures à prendre dépendent du problème spécifique et de l'urgence ou de l'importance de ce problème. En général, les utilisateurs d'une carte d'assurance ont la possibilité d'augmenter ou de diminuer l'assurance. Si une zone à faible risque présente un niveau d'assurance élevé, l'entité peut souhaiter envisager de déplacer ces ressources de certification vers une zone à risque élevé.

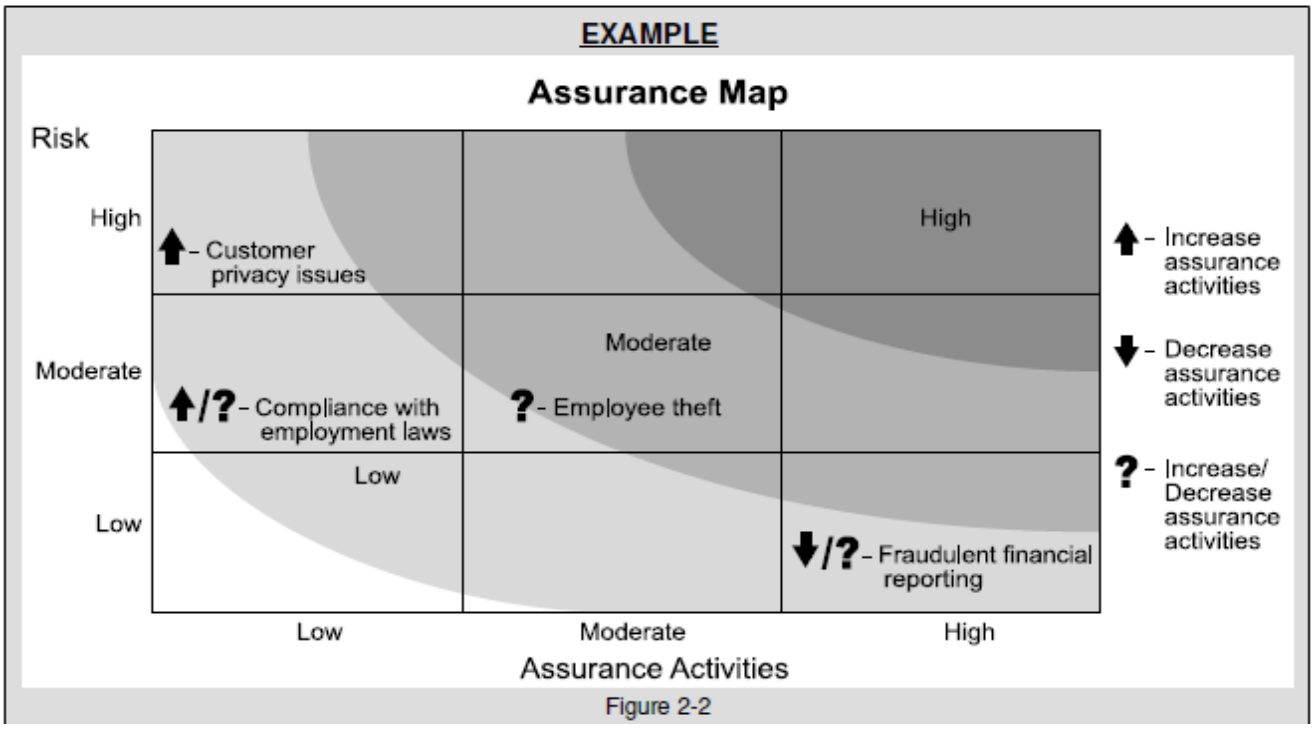

Figure 2-2

Remarques :

- Étant donné que les préoccupations en matière de confidentialité des clients sont devenues plus importantes, l'entité a déterminé qu'il était nécessaire d'accroître ses activités de certification liées à la confidentialité des clients.
- Le respect du droit du travail n'a pas été un problème auparavant. Cependant, en raison des récents changements législatifs, l'entité envisage d'augmenter ses activités de certification.
- En raison de l'équilibre entre les activités d'assurance et de risque, l'entité ne sait pas si elle doit augmenter ou diminuer les activités d'assurance.

- Le niveau des activités de certification relatives aux rapports financiers frauduleux est élevé. Par conséquent, l'entité envisage d'utiliser certaines ressources pour ces activités de certification

II. AUTO-ÉVALUATION DU RISQUE ET DU CONTRÔLE

1. Auto-évaluation des contrôles (CSA)

Les managers et les auditeurs ont un intérêt à utiliser des méthodes qui (1) améliorent l'évaluation des processus de management des risques et de contrôle et (b) identifient les moyens d'améliorer leur efficacité.

L'auto-évaluation des contrôles (CSA) augmente la prise de conscience du risque et du contrôle dans toute l'organisation. L'évaluation des risques, les processus métier et les contrôles internes ne sont pas considérés comme des préoccupations exclusives de la direction générale et de l'activité d'audit interne. Au lieu de cela, l'auto-évaluation des contrôles (CSA) implique le personnel du client, demande leur contribution et leur donne un sentiment de participation.

La **philosophie de base** de l'auto-évaluation des contrôles (CSA) est que le contrôle est la responsabilité de tous les membres de l'organisation. Les personnes qui travaillent dans le processus, c'est-à-dire les employés et les managers, sont invités à évaluer les risques et les contrôles dans leur processus.

Les candidats CIA devraient comprendre (1) les objectifs de l'auto-évaluation des contrôles (CSA), (2) ses avantages pour une organisation, (3) ses objectifs à long terme et (4) les contrôles les mieux évalués par le programme.

2. Éléments CSA

Un processus CSA typique comporte les éléments suivants :

- Travaux de planification et d'audit préliminaire.
- Une réunion en personne, impliquant généralement un arrangement de sièges de facilitation (Table en forme de U) et un facilitateur de réunion. Les participants sont des propriétaires de processus, c'est-à-dire la direction et le personnel qui (a) sont impliqués dans les problèmes particuliers examinés, (b) le connaissent mieux et (c) sont essentiels à la mise en œuvre de contrôles de processus appropriés.
- Un programme structuré est utilisé par le facilitateur pour diriger le groupe en examinant les risques et les contrôles du processus. Souvent, l'agenda est basé sur un cadre ou un modèle bien défini afin que les participants puissent être sûrs de résoudre tous les problèmes nécessaires. Un modèle peut se concentrer sur les contrôles, les risques ou un cadre développé pour ce projet.
- Une option est la présence d'un secrétaire pour effectuer une transcription en ligne de la session et la technologie de vote électronique pour permettre aux participants d'indiquer leur perception des problèmes de façon anonyme.
- Rapports et élaboration de plans d'action.

En conséquence, l'auto-évaluation des contrôles (CSA) utilise généralement une approche d'auto-évaluation de l'atelier qui est structurée, documentée et répétitive. Ainsi, il devrait être mis en contraste avec une approche qui ne fait qu'étudier les employés en ce qui concerne les risques et les contrôles.

3. Responsabilités

La direction générale devrait superviser l'établissement, l'administration et l'évaluation des processus de management des risques et de contrôle.

Les responsabilités des managers d'exploitation comprennent l'évaluation des risques et des contrôles dans leurs unités.

Les auditeurs internes et externes fournissent des degrés variés d'assurance sur l'état de l'efficacité des processus de management des risques et de contrôle de l'organisation.

4. Comment les auditeurs internes utilisent l'auto-évaluation des contrôles (CSA)

L'investissement de l'audit interne dans certains programmes CSA peut être important. Il peut parrainer, concevoir, mettre en œuvre et, en fait, s'approprier le processus ; conduire la formation ; fournir des facilitateurs, des secrétaires et des rapporteurs ; orchestrer la participation de la direction et des équipes de travail.

Mais dans d'autres organisations, l'audit interne ne peut servir que de partie intéressée et de consultant pour l'ensemble du processus et de vérificateur final des évaluations produites par les équipes.

Dans la plupart des programmes, l'investissement dans les efforts de l'auto-évaluation des contrôles de l'organisation se situe entre les deux extrêmes décrits ci-dessus. Au fur et à mesure que le niveau de participation au programme CSA et dans les délibérations des différents ateliers augmentent, le RAI (a) surveille l'objectivité du personnel d'audit interne, (b) prend des mesures pour gérer cette objectivité (si nécessaire) et (c) augmente les tests d'audit interne pour s'assurer que le jugement final du personnel reste neutre et impartial.

Un programme CSA augmente le rôle traditionnel de l'activité d'audit interne en aidant la direction à s'acquitter de ses responsabilités pour établir et maintenir des processus de gestion des risques et de contrôle, et en évaluant l'adéquation de ce système. Grâce à un programme CSA, l'activité d'audit interne et les unités et fonctions opérationnelles collaborent pour produire de meilleures informations sur la façon dont les processus de contrôle fonctionnent et sur l'importance des risques résiduels.

Bien qu'il fournisse au personnel un soutien sur le programme CSA en tant que facilitateur et spécialiste, l'activité d'audit interne constate souvent qu'il peut réduire les efforts déployés pour recueillir des informations sur les procédures de contrôle et éliminer certains tests. Un programme CSA (1) augmente la couverture des évaluations des processus de contrôle dans l'organisation, (2) améliore la qualité des mesures correctives prises par les propriétaires de processus et (3) concentre le travail de l'activité d'audit interne sur l'examen des processus à haut risque et des situations inhabituelles. Un programme CSA peut également se concentrer sur (1) la validation des conclusions d'évaluation produites par le processus CSA, (2) la synthèse des informations

recueillies à partir des composants de l'organisation et (3) l'expression de son jugement global sur l'efficacité des contrôles à la direction générale et au Conseil.

5. Caractéristiques principales

Le programme CSA comprend des enquêtes d'auto-évaluation et des ateliers facilités. C'est une approche utile et efficace pour les managers et les auditeurs internes de collaborer à l'évaluation des procédures de contrôle. Dans sa forme la plus pure, l'auto-évaluation des contrôles(CSA) intègre les objectifs commerciaux et les risques avec les processus de contrôle. L'auto-évaluation des contrôles(CSA) s'appelle également auto-évaluation de contrôles et des risques.

Bien que les praticiens CSA utilisent différentes méthodes et formats, la plupart des programmes mis en œuvre partagent certaines caractéristiques et objectifs clés. Une organisation qui utilise l'auto-évaluation aura un processus formel et documenté qui permet au management et aux équipes de travail qui sont directement impliquées dans une unité, une fonction ou un processus d'entreprise de participer de manière structurée aux fins de :

- Identification des risques et des expositions,
- Évaluation des processus de contrôle qui atténuent ou gèrent ces risques,
- Élaborer des plans d'action pour réduire les risques à des niveaux acceptables et
- Déterminer la probabilité d'atteindre les objectifs de l'entreprise.

6. Résultats

Les améliorations suivantes des contrôles sont générées par la CSA :

- Les membres des unités d'affaires sont formés et expérimentés pour évaluer les risques et pour associer des processus de contrôle à la gestion de ces risques, afin d'améliorer la probabilité d'atteindre les objectifs commerciaux.
- Les contrôles informels sont identifiés et évalués plus facilement.
- Les personnes sont motivées pour s'approprier des processus de contrôle de leur unité, et les actions correctives des équipes de travail sont souvent plus efficaces et plus rapides.
- Toute l'infrastructure objectifs-risques-contrôles d'une organisation fait l'objet d'une surveillance plus approfondie et d'une amélioration continue.
- Les auditeurs internes sont impliqués dans le processus d'auto-évaluation et acquièrent des connaissances à cet effet car ils jouent le rôle de facilitateurs, de secrétaires et de rapporteurs pour les équipes de travail ; ils interviennent également comme formateurs pour les concepts de risque et de contrôle à la base du programme CSA.
- L'activité d'audit interne acquiert davantage d'informations sur les processus de contrôle au sein d'une organisation. Elle peut exploiter ces informations supplémentaires pour attribuer ses ressources limitées, afin de consacrer plus d'efforts aux tests et aux enquêtes sur les unités d'affaires ou sur les fonctions qui présentent des contrôles beaucoup plus faibles ou des risques résiduels élevés.

- La responsabilité de la direction en matière de gestion des risques et de processus de contrôle est renforcée, si bien que les directeurs sont moins tentés d'abandonner ces activités à des spécialistes tels que les auditeurs.
- L'activité d'audit interne continue d'exercer son rôle principal, en particulier de valider les processus d'évaluation au moyen de tests et d'indiquer si, selon son opinion professionnelle, la gestion des risques et le système de contrôle sont entièrement adéquats et efficaces.

7. Approches

Les trois approches principales des programmes CSA sont (1) l'atelier d'équipe animé, (2) l'enquête (questionnaire) et (3) analyses produites par la direction. Les organisations combinent souvent des approches.

La variété des approches utilisées pour les processus CSA dans les organisations reflète les différences dans l'industrie, la géographie, la structure, la culture organisationnelle, le degré d'autonomisation des employés, le style de gestion dominante et la manière de formuler des stratégies et des politiques. Ainsi, le succès d'un type particulier de programme CSA dans une organisation peut ne pas être répliqué dans une autre. Le processus CSA doit être personnalisé pour tenir compte des caractéristiques uniques de chaque organisation. En outre, une approche CSA doit être dynamique et changer avec le développement continu de l'organisation.

8. Approche de l'atelier d'équipe animé

Les ateliers d'équipe animés recueillent des informations auprès des équipes de travail représentant les différents niveaux de la fonction ou de l'unité d'affaires. Ils peuvent être animés par le client ou par le personnel d'audit interne.

Voici différentes catégories d'ateliers :

- **Les ateliers basés sur les objectifs** se concentrent sur la meilleure façon d'atteindre un objectif commercial. L'atelier commence par identifier les contrôles actuellement en place pour soutenir l'objectif, puis détermine les risques résiduels restants. L'objectif de l'atelier est de décider si les procédures de contrôle fonctionnent efficacement et entraînent des risques résiduels à un niveau acceptable.
- **Les ateliers basés sur les risques** se concentrent sur la liste des risques pour atteindre un objectif. L'atelier commence par énumérer toutes les barrières possibles, les obstacles, les menaces et les expositions susceptibles d'empêcher l'atteinte d'un objectif, puis examine les procédures de contrôle pour déterminer si elles sont suffisantes pour gérer les principaux risques. L'objectif de l'atelier est de déterminer les risques résiduels importants. Ce format prend l'équipe de travail dans l'ensemble de la formule objectifs-risques-contrôles.
- **Les ateliers basés sur les contrôles** se concentrent sur la façon dont les contrôles en place fonctionnent. Ce format est différent des deux premiers car le facilitateur identifie les principaux risques et contrôles avant le début de l'atelier. Au cours de l'atelier, l'équipe de travail évalue à quel point les contrôles atténuent les risques et favorisent la réalisation des objectifs. L'objectif de l'atelier est de produire une analyse de l'écart entre la façon dont les

contrôles fonctionnent et la façon dont la direction s'attend à ce que ces contrôles fonctionnent.

- **Les ateliers basés sur les processus** se concentrent sur les activités sélectionnées qui sont des éléments d'une chaîne de processus. Les processus sont généralement une série d'activités connexes qui vont d'un point de départ à une fin, comme les différentes étapes dans les achats, le développement de produits ou la génération de revenus. Ce type d'atelier couvre généralement l'identification des objectifs de l'ensemble du processus et des différentes étapes intermédiaires. L'objectif de l'atelier est d'évaluer, mettre à jour, valider, améliorer et même rationaliser l'ensemble du processus et ses activités. Ce format d'atelier peut avoir une plus grande portée d'analyse qu'une approche basée sur le contrôle en couvrant plusieurs objectifs dans le processus et en soutenant les efforts de gestion simultanés, tels que la réingénierie, l'amélioration de la qualité et les initiatives d'amélioration continue.

9. Approche du questionnaire

La forme de sondage de l'auto-évaluation des contrôles (CSA) utilise un questionnaire qui tend à poser des questions simples "oui / non" ou "ont / n'ont pas" qui sont soigneusement écrites pour être comprises par les destinataires cibles.

Les enquêtes sont souvent utilisées si les répondants souhaités sont trop nombreux ou très dispersés pour participer à un atelier. Ils sont également préférés si la culture de l'organisation peut limiter les discussions ouvertes et franches dans les paramètres de l'atelier ou si la direction souhaite minimiser le temps passé et les coûts engagés dans la collecte de l'information.

10. Approche des analyses produites par la direction

Cette forme d'auto-évaluation est basée sur des analyses produites par la direction pour produire des informations sur les processus métier sélectionnés, les activités de gestion des risques et les procédures de contrôle. L'analyse est souvent destinée à parvenir à un jugement éclairé et en temps opportun sur les caractéristiques spécifiques des procédures de contrôle et est généralement préparé par une équipe dans un rôle de personnel ou de soutien.

L'auditeur interne peut synthétiser cette analyse avec d'autres informations afin d'améliorer la compréhension des contrôles et de partager les connaissances avec les managers dans les unités commerciales ou fonctionnelles dans le cadre du programme CSA de l'organisation.

11. Compréhension des risques et du contrôle

Tous les programmes d'autoévaluation supposent que les managers et les membres des équipes de travail comprennent les concepts de risque et de contrôle et les utilisent dans les communications.

Pour les séances de formation, pour faciliter le bon déroulement des discussions sur les ateliers et pour vérifier l'intégralité du processus global, les organisations utilisent souvent un cadre de contrôle, comme le modèle COSO.

12. Rapports de l'atelier

Dans l'atelier typique CSA facilité, un rapport est considérablement créé pendant les délibérations. Un consensus est enregistré pour les différents segments des discussions et le groupe passe en revue le rapport final proposé avant la fin de la dernière session.

Certains programmes utilisent un vote anonyme pour assurer la libre circulation de l'information et des opinions au cours des ateliers et pour aider à négocier les différences entre les groupes d'intérêt.

13. Limitations

L'auditeur interne peut ne pas utiliser efficacement la ou les approches CSA choisies, ou les personnes effectuant l'auto-évaluation peuvent ne pas être compétentes en gestion des risques et contrôle. Les risques et les contrôles pertinents peuvent alors ne pas être identifiés ou, s'ils sont identifiés, ne pas être correctement évalués.

III. AUDITS DE TIERS ET AUDIT DE CONTRAT

1. Relations avec d'autres entreprises

Les organisations ont plusieurs relations avec d'autres entreprises (EBR). Le Guide pratique de l'IIA, Auditing External Business Relationships, contient des conseils détaillés.

- Chaque EBR comporte des risques, et la direction est responsable de la gestion et du suivi des risques, ainsi que de la réalisation des avantages.
- L'audit interne aide la direction et valide ses efforts.
- Les EBR peuvent impliquer ce qui suit :
- Prestataires de services (par exemple, pour la prestation de services d'audit interne, le traitement de la paie, le partage de services ou l'utilisation de services informatiques)
- Partenaires de l'offre (par exemple, la sous-traitance de la production ou la R & D)
- Partenaires côté demande (p. Ex., Licenciés ou distributeurs)
- Les alliances stratégiques et les coentreprises (par exemple, le partage des coûts, des revenus et des bénéfices dans la production et le développement des médias)
- Partenaires de propriété intellectuelle (IP) (par exemple, licences de logiciels)

Entre autres choses, les partenaires de l'EBR peuvent offrir des coûts plus bas, une meilleure efficacité opérationnelle, une expertise particulière, des nouvelles technologies, une marque connue ou des économies d'échelle.

L'activité d'audit interne aide la direction et le conseil à identifier, évaluer et gérer les risques, y compris les risques de réputation ainsi que les risques économiques. Voici des exemples de risques importants d'EBR :

- Ils ne peuvent être identifiés et ne peuvent donc pas être (a) gérés conformément aux politiques pertinentes, (b) évalués, ou (c) surveillés.

- Les EBR peuvent nuire à la réputation de l'organisation, par exemple en violant les lois, en commettant des fraudes ou en ne respectant pas les contrats.
- Les EBR peuvent avoir une couverture d'assurance insuffisante.
- Les niveaux de service ou les produits peuvent être insatisfaisants, par exemple en raison d'une définition inadéquate du contrat.
- Des conflits d'intérêts peuvent survenir, par exemple, lorsque le travail est affecté par les obligations contractuelles de l'EBR envers d'autres.
- L'octroi de licences de propriété intellectuelle peut entraîner une mauvaise utilisation, un vol ou une perte de revenus.
- L'organisation peut être surchargée pour les services.
- Le partenaire de l'EBR peut devenir insolvable.
- Les informations confidentielles de l'organisation (par exemple, les informations personnelles identifiables) peuvent être perdues.

2. Audit des relations avec d'autres entreprises (EBR)

Les auditeurs internes doivent comprendre tous les éléments d'une EBR :

- Démarrage de l'EBR
- Contrats et définitions de l'EBR
- Approvisionnement
- Gestion et suivi de l'EBR (y compris les contraintes d'environnement de contrôle sur l'objectivité et l'indépendance des managers)
- Arrêt de l'EBR

Les auditeurs internes doivent comprendre les attentes des parties et les processus de gestion et de suivi de l'EBR. Ils développent ensuite un programme d'audit approprié avec des objectifs pertinents. Les procédures d'audit interne peuvent inclure l'évaluation de la conformité au contrat pour déterminer si les obligations monétaires et non monétaires sont respectées. Les procédures d'audit peuvent découvrir les revenus manqués ou les économies de coûts, améliorer les rapports et ajouter de la valeur à l'EBR par le biais de ce qui suit :

- Limitation de la fraude
- Augmentation de la confiance
- Favoriser les commentaires
- Améliorer les relations
- Aider la direction à améliorer les contrôles internes et externes

Le RAI décide de vérifier (1) chaque EBR séparément, (2) certains EBR, ou (3) le processus EBR en entier. Voici le cycle d'un audit EBR :

- **Comprendre l'organisation, son environnement, ses processus et la nature de chaque EBR.** Les auditeurs internes doivent comprendre (1) les raisons et l'importance des EBR ; (2) s'ils ont été identifiés ; et (3) les risques de non-conformité par les partenaires de l'EBR.
- **Évaluation des risques et des contrôles.** Les auditeurs internes doivent (1) comprendre les risques inhérents à l'EBR et la conception des contrôles pertinents ; (2) déterminer les contrôles clés ; et (3) comprendre l'environnement, les processus et les contrôles du partenaire de l'EBR (y compris le travail effectué par ses auditeurs).
- **Exécution de l'audit.** Les auditeurs internes doivent déterminer s'ils doivent (1) effectuer des travaux sur le site de l'EBR, (2) évaluer les résultats, (3) identifier les résultats et leur application (à une EBR, certaines EBR ou le processus EBR total), et (4) parvenir à des conclusions.
- **Rapports.** Les auditeurs internes doivent déterminer la fréquence et le contenu des rapports destinés au conseil et à la direction générale.
- **Suivi des progrès.** Les auditeurs internes peuvent déterminer si les constatations (en particulier les lacunes) ont été abordées. Ils peuvent également aider à déterminer si les EBR sont bien gérés.

3. Audit des tiers

L'organisation peut être vérifiée. C'est une routine pour les organisations qui émettent des états financiers d'usage général et de nombreuses EBR. Par exemple, si l'organisation est un fournisseur de services, les auditeurs externes et internes des clients de l'organisation doivent obtenir l'assurance de la sécurité des opérations de l'organisation et de l'exécution des obligations contractuelles. De tels contrôles sont également communs aux coentreprises. Un autre audit typique de tiers est l'audit effectué par un registraire qualifié dans le cadre du processus de certification ISO 9000.

Dans ces cas, les auditeurs internes devraient coordonner leurs activités avec ceux d'auditeurs tiers afin de partager des informations et d'éviter les doubles emplois.

4. Audit du contrat

L'audit des contrats se réfère généralement à l'audit des contrats de type construction ou des contrats d'exploitation. Ces deux grandes catégories peuvent être divisées en trois types distincts de contrats :

- **Contrats à prix forfaitaire**. Ces contrats sont établis pour un prix total conformément à certaines spécifications ou exigences. En théorie, si le contrat est exécuté avec peu ou pas de modification, il n'y a généralement pas besoin d'un auditeur interne. Cependant, dans la pratique, ces types de contrats sont rarement conclus sans considérations supplémentaires ou contingences, y compris des paiements progressifs, des clauses d'indexation, des pénalités de retard et d'autres ajustements de coûts. Des problèmes d'audit surviennent à la suite des changements qui compliquent les détails du contrat. Certains des risques associés aux contrats à prix forfaitaires sont les suivants :

- ✓ Concurrence, assurance ou couverture des obligations insuffisante
- ✓ Certification d'achèvement même si le travail n'est pas terminé
- ✓ Les frais pour l'équipement ou les activités qui ne sont pas reçus
- ✓ Les dispositions d'escalade peuvent être exercées inutilement
- ✓ Les changements dans les spécifications ou les prix et l'autorisation pour les extras et les révisions peuvent faire augmenter les coûts contractuels en dehors du processus officiel d'appel d'offres et d'autorisation.
- ✓ Les extras, les modifications et les révisions qui font déjà partie du contrat d'origine peuvent être facturés à nouveau
- ✓ Des frais supplémentaires peuvent être ajoutés pour les frais généraux qui ne devraient pas être inclus
- ✓ Le contenu des ordres de modification, y compris les frais appropriés, peut ne pas être autorisé de manière appropriée
- ✓ Inspection inadéquate par rapport aux spécifications

- **Contrats en régie ou à frais remboursables**. Pour les contrats à frais remboursables, l'acheteur paie le coût d'exécution du contrat plus un montant fixe en dollars ou un pourcentage du coût pour l'entrepreneur. L'avantage d'un contrat à frais remboursables est qu'il peut être utilisé pour des projets comportant de nombreux facteurs inconnus importants. Le désavantage des contrats à frais remboursables est que le producteur n'est guère incité à être économe ou efficace. Par conséquent, l'auditeur interne de la société acheteuse sera probablement impliqué dans la surveillance des coûts imputés au contrat. Les problèmes de vérification surviennent parce que les motifs d'économie de coûts ne sont peut-être pas soulignés lors de l'exécution du contrat. Les risques associés aux contrats à frais remboursables sont les suivants :
  - ✓ Les frais généraux sont également facturés directement
  - ✓ Contrôle interne inadéquat par l'entrepreneur sur les frais pour les personnes, les matériaux et les services
  - ✓ Frais déraisonnables pour l'utilisation de l'équipement appartenant à l'entrepreneur
  - ✓ Dotation excessive
  - ✓ Aucun effort pour obtenir les meilleurs prix pour les matériaux et l'équipement
  - ✓ Les factures dépassant les montants que l'entrepreneur paie pour la main-d'œuvre ou le matériel
  - ✓ Défaut de créditer le projet pour des rabais, pour le remboursement du taux d'assurance, ou pour le matériel retourné ou récupéré
  - ✓ Duplication des efforts ou des coûts entre le siège et les bureaux extérieurs

- ✓ Supervision inadéquate du chantier ou inspection par un entrepreneur ou par des ingénieurs architectes
- ✓ Communication et suivi inadéquats du siège
- ✓ Procédures de comptabilité et de rapport des coûts non fiables par un entrepreneur
- ✓ La supervision de la facturation comme "travail direct" en violation des termes du contrat
- ✓ Equipement loué au ralenti
- ✓ Mauvaises pratiques de travail et mauvaise qualité de la main-d'œuvre
- ✓ Utilisation extravagante ou arrivée précoce de matériaux et de fournitures
- ✓ Normes excessivement élevées et mauvaise protection physique des matériaux et de l'équipement
- ✓ Manque de contrôle sur les absences des employés de l'entrepreneur et sur les heures supplémentaires incontrôlées
- ✓ Travail de type Coût-plus en cours simultanément avec un travail de type fixe
- ✓ Coûts excessifs encourus en raison de la négligence d'un entrepreneur

- **Contrats à prix unitaires**. Dans ces contrats, le coût par unité est fixé ; toutefois, les unités totales seront spécifiées au moment de l'exécution du contrat (par exemple, hectares à défricher, mètres cubes à transporter ou mètres carrés devant être surveillés par un service de sécurité). Afin de protéger les intérêts de l'entreprise, les auditeurs internes doivent évaluer ce qui suit :
  - ✓ Procédures d'enchères (telles que les enchères concurrentielles)
  - ✓ Estimation des coûts et contrôle des coûts
  - ✓ Traitements fiscaux
  - ✓ Conditions du contrat et des plans de paiement progressif
  - ✓ Budgets et prévisions financières, disponibilité des ressources et sources de financement
  - ✓ Systèmes de comptabilité et de gestion de l'entrepreneur
  - ✓ Obligation de performance requise

Les risques associés aux contrats à prix unitaires sont les suivants :

- ✓ Paiements progressifs excessifs
- ✓ Notification incorrecte des unités achevées
- ✓ Les prix n'ont aucun rapport avec le coût
- ✓ Modifications incorrectes du contrat original
- ✓ Ajustements d'escalade non autorisés

- ✓ Des dossiers de terrain inexacts ou une extension inexacte des prix unitaires

Pour protéger l'organisation, les auditeurs internes doivent être impliqués tout au long du processus de passation de marchés, et pas seulement dans la phase de performance. Ils devraient revoir les termes du contrat et ce qui suit :

- ✓ Procédures d'enchères (par exemple, appel d'offres concurrentiel)
- ✓ Procédures d'estimation et de contrôle des coûts
- ✓ Budgets et prévisions financières
- ✓ Les systèmes d'information et de contrôle de l'entrepreneur
- ✓ La situation financière de l'entrepreneur
- ✓ Financement et questions fiscales
- ✓ L'avancement du projet et les coûts encourus

Lors de l'examen d'un contrat d'achat de systèmes d'application d'affaires, l'auditeur interne devrait recommander que le contrat contienne une clause d'entiercement de code source.

Une clause d'entiercement de code source exige que le code source de l'application soit détenu en main tierce par un tiers de confiance. Le tiers libère le code source à l'acheteur, ou au licencié, à la survenance d'un événement, ou d'événements, spécifiés dans la clause.

IV. AUDIT DE QUALITÉ

1. Audit de qualité

Le rôle de l'activité d'audit interne est d'assurer que les structures de qualité approuvées sont en place et que les processus de qualité fonctionnent comme prévu.

2. Vues traditionnelles et modernes de la qualité

La vision traditionnelle de la qualité a mis l'accent sur la détection de produits qui ne répondent pas aux normes. Ce point de vue implique le rejet ou le retraitement des produits défectueux.

La vision moderne est que la qualité est une activité à valeur ajoutée effectuée dans tous les processus, de la conception du produit à l'acquisition de matières premières et à l'inspection finale. Il s'étend également à tous les processus métier de l'organisation, pas seulement à la production de biens. Cette vision de la qualité est la base de la gestion de la qualité totale (TQM).

3. Gestion de la qualité totale (TQM)

La TQM peut augmenter les revenus et réduire considérablement les coûts. Ainsi, les services de l'activité d'audit interne en ce qui concerne la fonction de qualité peuvent ajouter une valeur substantielle. En effet, l'amélioration des opérations fait partie de la définition de l'audit interne. La qualité est mieux vue depuis plusieurs points de vue :

- Attributs du produit (performance, maintenance, durabilité, etc.)
- Satisfaction du client,
- Conformité aux spécifications de fabrication, et

- Valeur (relation de qualité et de prix).

La TQM est une approche globale. Elle traite de la recherche de la qualité en tant que fonction organisationnelle de base qui est aussi importante que la production ou le marketing. C'est aussi une arme stratégique car ses effets cumulatifs ne peuvent pas être facilement reproduits par les concurrents. La TQM est la **poursuite continue de la qualité** dans tous les aspects des activités organisationnelles à travers :

- Une philosophie de bien faire la première fois,
- Formation et habilitation des employés,
- Promotion du travail d'équipe,
- Amélioration des processus, et
- Attention à la satisfaction des clients internes et externes.

La TQM met l'accent sur la relation du fournisseur avec le client et identifie les besoins des clients. Elle reconnaît également que tout le monde dans un processus est à un moment donné un client ou un fournisseur de quelqu'un d'autre, que ce soit à l'intérieur ou à l'extérieur de l'organisation. Ainsi, TQM commence par les exigences externes du client, identifie les relations et les exigences internes client-fournisseur et établit les exigences pour les fournisseurs externes.

La gestion de la qualité ne se limite pas au personnel de gestion de la qualité, aux ingénieurs, au personnel de production, etc. Compte tenu de la portée de la TQM et de l'activité d'audit interne, le rôle des auditeurs internes est d'évaluer toute la fonction de qualité. L'activité d'audit interne est bien qualifiée pour effectuer des évaluations des risques et promouvoir l'amélioration continue des contrôles. Le personnel impliqué dans les améliorations techniques des processus peut ne pas être qualifié en matière de gestion des risques et de contrôle. L'activité d'audit interne effectue des procédures pour garantir que les objectifs de base de la TQM sont atteints : la satisfaction du client, l'amélioration continue et la promotion du travail d'équipe.

Les concepts de la TQM s'appliquent également aux opérations de l'activité d'audit interne elle-même. Par exemple, les évaluations internes périodiques de ces opérations peuvent "inclure l'analyse comparative des pratiques de l'activité d'audit interne et des indicateurs de performance en fonction des meilleures pratiques pertinentes de la profession.

V. AUDITS DE SÉCURITÉ ET DE CONFIDENTIALITÉ

REMARQUE : La sécurité physique, comme les garanties contre les risques environnementaux et l'accès illicite aux ordinateurs, doit être vérifiée même si le logiciel fournit la plus grande partie de la protection de l'information.

1. Audit de la sécurité de l'information

L'audit de la sécurité de l'information est une extension des services d'assurance assurés par les auditeurs. La création de réseaux informatiques à l'échelle de l'organisation avec le potentiel d'accès de nombreuses parties extérieures a considérablement augmenté le risque. Ainsi, la gestion des risques et les processus de contrôle peuvent être inadéquats. Le rôle de l'activité d'audit interne

dans ces circonstances est d'évaluer les risques, de surveiller la mise en œuvre des mesures correctives et d'évaluer les contrôles.

L'activité d'audit interne peut également fonctionner en capacité de consultation en identifiant les problèmes de sécurité et en travaillant avec les utilisateurs des systèmes d'information et avec le personnel de sécurité des systèmes pour concevoir et mettre en œuvre des contrôles. L'activité d'audit interne travaille en étroite collaboration avec la direction générale et le conseil pour aider à la performance de la fonction de gouvernance en matière de sécurité de l'information.

Norme de mise en œuvre 2130.A1

L'audit interne doit évaluer la pertinence et l'efficacité du dispositif de contrôle choisi pour faire face aux risques relatifs au gouvernement d'entreprise, aux opérations et systèmes d'information de l'organisation. Cette évaluation doit porter sur les aspects suivants :

- ✓ L'atteinte des objectifs stratégiques de l'organisation
- ✓ La fiabilité et l'intégrité des informations financières et opérationnelles ;
- ✓ L'efficacité et l'efficience des opérations et des programmes ;
- ✓ La protection des actifs ;
- ✓ le respect des lois, règlements, règles, procédures et contrats.

Fiabilité et intégrité de l'information :

- La fiabilité et l'intégrité de l'information comprennent l'exactitude, l'exhaustivité et la sécurité. Les auditeurs internes s'assurent que la direction générale et le Conseil sont conscients de la responsabilité du management en matière de fiabilité et d'intégrité de l'information. Cette responsabilité porte sur toutes les informations essentielles pour l'organisation, quel que soit leur mode de conservation.
- Le RAI détermine si l'activité d'audit interne dispose de ressources d'audit compétentes pour évaluer les risques internes et externes liés à la fiabilité et à l'intégrité de l'information.
- Le RAI détermine si la direction générale, le conseil et l'activité d'audit interne seront avisés rapidement des violations et des conditions pouvant constituer une menace.
- Les auditeurs internes évaluent, le cas échéant, l'efficacité des mesures prises, en vue de prévenir, détecter et atténuer les attaques survenues par le passé, ainsi que tout incident ou tentative d'attaque susceptible de se produire à l'avenir. Les auditeurs internes s'assurent que le Conseil a bien été informé des menaces ou incidents survenus, des faiblesses exploitées et des mesures correctives.
- Les auditeurs internes évaluent périodiquement les pratiques de fiabilité et d'intégrité et recommandent des contrôles nouveaux ou améliorés. Ces évaluations peuvent être réalisées en tant que missions distinctes ou en tant que missions multiples intégrées à d'autres éléments du plan d'audit.

Les auditeurs internes évaluent également la conformité aux lois et règlements sur la protection de la vie privée. Ainsi, ils évaluent l'adéquation de l'identification des risques et les contrôles qui réduisent ces risques.

2. Audit de sécurité

L'utilisation la plus courante du terme « sécurité » dans un contexte organisationnel est liée à la technologie de l'information (TI). Cependant, l'organisation doit prendre une vue plus complète de la sécurité. Un exemple est la protection des employés et des visiteurs contre les violences au travail. Ainsi, la sécurité est une question de gouvernance et de gestion des risques appropriée même en l'absence d'informatique.

L'activité d'audit interne évalue l'adéquation et l'efficacité des contrôles conçus et mis en œuvre par la direction dans tous les domaines de la sécurité.

3. Audit de la confidentialité

La quantité d'informations personnelles stockées sur les ordinateurs a considérablement augmenté. Les risques de sécurité ont également augmenté en raison des interconnexions entre ordinateurs autorisés par Internet.

Évaluation d'un cadre de protection de la vie privée

- La protection des renseignements personnels empêche de telles conséquences organisationnelles négatives comme la responsabilité légale et la perte de réputation.
- Voici différentes définitions de la vie privée :
  - ✓ Vie privée des personnes (sur le plan physique et psychologique)
  - ✓ Confidentialité de l'espace (absence de surveillance)
  - ✓ Confidentialité de la communication (absence de contrôle)
  - ✓ Confidentialité de l'information (collecte, exploitation et diffusion par autrui d'informations à caractère personnel)
- Les informations personnelles sont des informations qui peuvent être associées à une personne spécifique ou qui peuvent être combinées avec d'autres informations pour le faire. Voici des exemples :
  - ✓ Nom, adresse, numéros d'identification, relations familiales
  - ✓ Dossiers d'employés, évaluations, commentaires, statut social ou mesures disciplinaires
  - ✓ Dossiers de crédit, revenu, situation financière
  - ✓ Statut médical
- Le conseil est ultimement responsable de l'identification des principaux risques, de la mise en œuvre des contrôles et de la gestion du risque lié à la protection de la vie privée, par exemple en établissant et en surveillant un cadre de protection de la vie privée.

- L'audit interne peut contribuer à un bon gouvernement d'entreprise et au management des risques en évaluant l'adéquation de l'identification des risques réalisée par le management en ce qui concerne la protection de la vie privée et des contrôles mis en place pour atténuer ces risques à un niveau acceptable. L'auditeur interne est bien placé pour évaluer le dispositif en place dans l'organisation, identifier les risques significatifs et formuler les recommandations appropriées en vue de leur atténuation. L'activité d'audit interne considère également
  - ✓ Lois, règlements et pratiques dans les juridictions concernées ;
  - ✓ Les conseils d'un avocat ; et
  - ✓ Les efforts de sécurité des informaticiens.
- Le rôle de l'audit interne dépend du niveau ou de la maturité des pratiques de confidentialité de l'organisation. En conséquence, les auditeurs internes peuvent
  - ✓ Faciliter le développement et la mise en œuvre du programme de confidentialité,
  - ✓ Évaluer l'évaluation des risques pour la vie privée de la direction, où
  - ✓ Effectuer un service d'assurance concernant l'efficacité du cadre de protection de la vie privée.

  Cependant, la prise en charge peut porter atteinte à l'indépendance.
- L'auditeur interne identifie
  - ✓ Les informations personnelles collectées,
  - ✓ Les méthodes de collecte, et
  - ✓ L'utilisation de l'information est-elle conforme à l'usage prévu et à la loi applicable ?
- Compte tenu de la difficulté des problèmes techniques et juridiques, l'activité d'audit interne doit posséder les connaissances et les compétences nécessaires pour évaluer les risques et les contrôles du cadre de protection de la vie privée.

Utilisation des renseignements personnels dans l'exécution des missions

- Les progrès dans les TI et les communications présentent des risques et des menaces pour la vie privée. Ainsi, les auditeurs internes doivent prendre en compte la protection des informations personnellement identifiables collectées lors des audits. Les contrôles de confidentialité sont des exigences légales dans de nombreuses juridictions.
- De nombreuses juridictions exigent que les organisations identifient les finalités pour lesquelles les informations personnelles sont collectées au moment de la collecte ou avant. Ces lois interdisent également l'utilisation et la divulgation de renseignements personnels à des fins autres que celles pour lesquelles ils ont été recueillis, sauf avec le consentement de la personne ou selon les exigences de la loi.
- Les auditeurs internes doivent comprendre et respecter toutes les lois concernant l'utilisation des informations personnelles.

- Il peut être inapproprié ou illégal d'accéder, de récupérer, de réviser, de manipuler ou d'utiliser des renseignements personnels dans le cadre de certaines missions. Si l'auditeur interne accède à des informations personnelles, des procédures peuvent être nécessaires pour protéger ces informations. Par exemple, l'auditeur interne peut ne pas enregistrer les informations personnelles dans les dossiers de mission dans certaines situations.
- L'auditeur interne peut demander conseil à un juriste avant de commencer un travail d'audit si des questions se posent concernant l'accès aux informations personnelles.

Les missions de confidentialité concernent la sécurité des informations personnelles, en particulier les informations stockées dans des systèmes informatiques. Un exemple est l'information sur les soins de santé dans les dossiers des assureurs et des fournisseurs.

- L'organisation doit se conformer aux mandats statutaires et réglementaires du gouvernement. Les auditeurs internes consultent les conseillers juridiques de l'organisation et communiquent ensuite les exigences aux responsables de la conception et de la mise en œuvre des garanties requises. Les auditeurs internes déterminent que les exigences sont incorporées dans le système d'information et que la conformité est atteinte dans son fonctionnement.
- Les informations personnelles doivent être protégées contre toute intrusion non autorisée et toute utilisation abusive par ceux qui ont un accès autorisé.
- La protection de la vie privée est équilibrée par la nécessité de permettre une disponibilité appropriée et rapide des informations personnelles aux utilisateurs légitimes.
- L'organisation documente la conformité à la vie privée et d'autres exigences légales.
- Les avantages des mesures de sécurité devraient dépasser les coûts. Par exemple, le cryptage est un moyen coûteux d'aborder les menaces à la sécurité des informations privées. D'autres méthodes, telles que les contrôles d'accès, peuvent être plus appropriées par rapport au risque évalué.

NOTE : Le Code de déontologie de l'IIA exige des auditeurs internes de maintenir la confidentialité des informations privées.

> *Les auditeurs internes doivent être prudents dans l'utilisation et la protection des informations acquises dans l'exercice de leurs fonctions (Règle de conduite 3.1). Les auditeurs internes ne doivent pas utiliser l'information pour un gain personnel ou de quelque manière que ce soit contraire à la loi ou préjudiciable aux objectifs légitimes et éthiques de l'organisation (règle de conduite 3.2).*

VI. AUDIT DE PERFORMANCE

1. Audit de performance

Les auditeurs internes peuvent effectuer un audit de performance pour fournir l'assurance des **indicateurs clés de performance** de l'organisation. Ils peuvent également mener une mission de conseil pour concevoir un tel système de mesure du rendement.

Les auditeurs internes évaluent la capacité d'une organisation à mesurer son rendement, à reconnaître les limites et à prendre des mesures correctives. Un contrôle efficace du management nécessite une mesure du rendement et un feedback. Ce processus affecte l'allocation des ressources aux sous-unités organisationnelles. Cela affecte également les décisions concernant la rémunération des managers, l'avancement et les affectations futures. En outre, l'évaluation de leur performance sert à motiver les managers pour optimiser les mesures dans le modèle d'évaluation du rendement. Cependant, ce modèle peut être incompatible avec le modèle d'organisation pour la prise de décision managériale. Pour assurer la cohérence, les modèles doivent être synchronisés. Par exemple, si la direction générale souhaite maximiser les résultats sur le long terme, les subordonnés devraient être évalués sur le long terme.

Un tableau de bord équilibré est utile pour la mesure du rendement. C'est un rapport qui relie les facteurs de succès critiques déterminés dans une analyse stratégique avec des mesures financières et non financières des éléments de performance. Une organisation identifie ses facteurs de succès critiques au moyen d'une analyse qui traite des facteurs internes (forces et faiblesses) et des facteurs externes (opportunités et menaces). Ce processus est l'analyse **FFOM (Forces, Faiblesses, Opportunités, Menaces)**.

Les plus grandes forces de l'entreprise sont ses compétences essentielles. Ce sont les bases de sa capacité à concurrencer avec succès et à réaliser sa stratégie.

Les forces et les faiblesses sont des ressources internes ou un manque de ressources. Par exemple, les points forts comprennent des produits technologiquement avancés, un large mélange de produits, une gestion capable, un leadership en R & D, des installations de production modernes et une organisation de marketing solide. Les faiblesses résultent du manque de tels avantages.

Les opportunités et les menaces découlent de facteurs externes à l'organisation tels que la réglementation gouvernementale, les progrès technologiques et les changements démographiques. Ils peuvent se refléter dans certaines conditions de concurrence, y compris les suivantes :

- Le nombre et la force des concurrents dans l'industrie de l'entreprise
- Changements dans l'intensité de la rivalité au sein de l'industrie, par exemple en raison de la capacité de production excessive
- La disponibilité relative de substituts pour les produits ou services de l'entreprise
- Pouvoir de négociation des clients
- Le pouvoir de négociation des fournisseurs

L'analyse FFOM aide l'entreprise à déterminer sa stratégie en mettant l'accent sur les facteurs de base du coût, de la qualité et de la rapidité du développement et de la livraison des produits.

Une fois que l'entreprise a identifié ses facteurs de succès critiques, elle doit établir des mesures spécifiques pour chaque facteur pertinent pour le succès de l'entreprise et déclaré de manière fiable. Les mesures doivent être aussi bien **financières** que **non financières**, aussi bien à **long terme** qu'à **court terme**, aussi bien **internes** qu'**externes**.

Le tableau de bord équilibré met l'accent sur les résultats financiers à court terme et met l'accent sur les facteurs essentiels aux succès futurs. L'élaboration et la mise en œuvre d'un tableau de bord global équilibré nécessitent une participation active de la direction générale. Le tableau de bord devrait contenir des mesures détaillées pour permettre à chacun de comprendre comment ses efforts affectent les résultats de l'entreprise. La fiche de pointage et la stratégie qu'elle représente doivent être communiquées à tous les managers et utilisées comme base pour les décisions de compensation. Le tableau de bord devrait permettre de déterminer si certains objectifs sont atteints au détriment des autres. Par exemple, la réduction des dépenses en service à la clientèle peut améliorer les résultats financiers à court terme, mais entraîner une baisse de la satisfaction de la clientèle. Un tableau de bord équilibré typique comprend des mesures dans quatre catégories :

- **Finances.** Ce sont des mesures des résultats ultimes fournis aux propriétaires, par exemple, les ventes, la juste valeur des stocks de l'entreprise, les bénéfices, la liquidité et la part de marché.
- **Client.** Ce sont des mesures des besoins et de la satisfaction des clients, par exemple, le taux de fidélisation des clients, les relations avec les concessionnaires et les distributeurs, les performances de marketing et de vente, la livraison rapide et la qualité.
- **Interne.** Il s'agit des mesures des processus clés qui orientent l'entreprise, par exemple, la qualité, la productivité (une relation entrée-sortie), la flexibilité de la réponse aux conditions changeantes, la disponibilité opérationnelle et la sécurité.
- **Apprentissage, croissance et innovation**. Ce sont des mesures de base pour le succès futur (personnes et infrastructures), par exemple, le développement de nouveaux produits, la rapidité de leur introduction, le développement des ressources humaines, le moral et la compétence de la main-d'œuvre.

VII. AUDIT OPÉRATIONNEL

1. Missions d'audits opérationnels

Les auditeurs internes peuvent effectuer un audit opérationnel pour évaluer l'efficacité et l'efficience des opérations d'une organisation. Voici des missions typiques d'audit opérationnel :

Les missions de processus (fonctionnelles) sont des missions d'audit opérationnel qui suivent un processus traversant des lignes organisationnelles, des unités de service et des emplacements géographiques. L'accent est mis sur les opérations et la manière dont les unités organisationnelles concernées coopéreront de façon efficace et efficiente. Ces missions ont tendance à être difficiles en raison de leur portée et de la nécessité de traiter des unités organisationnelles qui peuvent avoir des objectifs contradictoires. Les processus ou les fonctions typiques sont :

- Achat et réception
- Distribution de services, de matériaux et de fournitures aux utilisateurs de l'organisation
- Modification des produits
- Pratiques de sécurité

- Traitement et élimination des déchets
- Développement des budgets
- Marketing
- Gestion des actifs amortissables

Les missions de résultats – programme visent à obtenir de l'information sur les coûts, les extrants, les avantages et les effets d'un programme. Ils tentent de mesurer l'accomplissement et le succès relatif de l'entreprise. Parce que les avantages ne peuvent souvent pas être quantifiés en termes financiers, une préoccupation particulière est la capacité de mesurer l'efficacité. Ainsi, des définitions claires des objectifs et des normes devraient être fournies au début du programme. Un programme est une activité financée qui ne fait pas partie des opérations normales et continues de l'organisation, comme une expansion ou un nouveau système d'information.

Les mesures utilisées pour évaluer l'efficacité et l'efficience sont les suivantes :

- Le ratio de productivité mesure la production par rapport à l'entrée.
- L'indice de productivité mesure le potentiel de production.
- Le taux d'utilisation des ressources mesure l'utilisation des ressources par rapport aux ressources disponibles.
- Le ratio d'exploitation mesure l'efficacité opérationnelle d'une organisation.

VIII. AUDIT DE LA CONFORMITE

1. Conformité

Le glossaire de l'IIA définit la conformité comme l'adhésion aux politiques, aux plans, aux procédures, aux lois, aux règlements, aux contrats ou à d'autres exigences.

Les auditeurs internes évaluent la conformité dans des domaines spécifiques dans le cadre de leur rôle dans la gouvernance organisationnelle. Ils procèdent également à un suivi et font rapport sur la réponse de la direction aux examens des organismes de réglementation. Compte tenu de la portée de la réglementation gouvernementale, ces fonctions des auditeurs internes revêtent une grande importance.

Attention : *les auditeurs internes sont encouragés à consulter un juriste dans toutes les questions impliquant des problèmes juridiques. Les exigences peuvent varier considérablement selon les différentes juridictions.*

Les responsabilités de l'activité d'audit interne en matière de conformité sont abordées dans deux normes de mise en œuvre.

L'activité d'audit interne doit évaluer les risques liés à la gouvernance, aux opérations et aux systèmes d'information en ce qui concerne (a) la conformité (**Norme de mise en œuvre 2120.A1**) et (b) l'adéquation et l'efficacité des contrôles répondant à ces risques (**Norme de mise en œuvre 2130.A1**).

2. Programmes

Les programmes de conformité aident les organisations à prévenir les violations involontaires des employés, à détecter les actes illégaux et à décourager les violations intentionnelles des employés. Ils aident également (1) à prouver les réclamations d'assurance, (2) déterminer la responsabilité des administrateurs et des dirigeants, (3) créer ou améliorer l'identité de l'entreprise, et (4) décider de la pertinence des dommages-intérêts punitifs.

Les auditeurs internes doivent évaluer les programmes de conformité réglementaire d'une organisation. Le RAI devrait rencontrer les organismes de réglementation pour fournir des informations pertinentes ou recevoir des conseils sur la conformité nécessaire.

3. Normes et procédures organisationnelles

L'organisation établit des normes et procédures de conformité à suivre par ses employés et d'autres agents qui sont raisonnablement capables de réduire la probabilité de conduite criminelle. Ils comprennent ce qui suit :

- Un code de conduite commercial clairement écrit, direct et équitable qui fournit des conseils aux employés sur les problèmes pertinents et est convivial ;
- Un organigramme identifiant le personnel responsable des programmes de conformité ;
- Incitations financières qui ne récompensent pas l'inconduite ;
- Pour une organisation internationale, un programme de conformité à l'échelle mondiale qui reflète les conditions et les lois locales.

4. Responsabilité

Un personnel spécifique de haut niveau qui est correctement habilité et doté des ressources nécessaires devrait être responsable du programme de conformité. La direction générale devrait également être impliquée. Le personnel de haut niveau devrait avoir un contrôle important de l'organisation ou un rôle important dans la formulation des politiques. Le personnel de conformité devrait avoir un accès adéquat à la direction générale, et le responsable de la conformité devrait rapporter directement auprès du directeur général.

5. Sélection du candidat

Un soin doit être utilisé pour éviter de déléguer l'autorité à ceux qui ont tendance à s'engager dans des activités illégales. Les demandes devraient se renseigner sur les condamnations ou la discipline pénale par les conseils d'autorisations. Tous les candidats doivent être soumis à un contrôle légal qui ne porte pas atteinte aux droits à la vie privée. Le but est de détecter des preuves d'actes répréhensibles passés, en particulier dans l'industrie de l'organisation.

6. Communication

Les normes et les procédures, y compris les documents relatifs à l'éthique disponibles, devraient être communiquées efficacement, de préférence dans un format interactif et à plusieurs reprises. Les programmes de formation et les publications sont des méthodes typiques. La meilleure formation permet aux employés de pratiquer de nouvelles techniques et d'utiliser de nouvelles

informations. Les informations de conformité devraient être transmises par diverses sources. En outre, il devrait être ciblé sur les domaines importants pour chaque groupe d'employés fonctionnels et ses exigences professionnelles. Par exemple, les informations sur la conformité environnementale devraient être dirigées vers des sous-unités, telles que la fabrication, qui sont plus susceptibles de violer (ou de détecter des violations de) ces lois et règlements. Les nouveaux employés devraient recevoir une formation de conformité de base dans le cadre de leur orientation, et les agents de l'organisation devraient recevoir une présentation spécifique pour eux. Les agents doivent comprendre les valeurs fondamentales de l'organisation et que leurs actions seront surveillées. Les organisations devraient également obliger les employés à certifier périodiquement qu'ils ont lu, compris et respecté le code de conduite. Cette information est transmise annuellement à la direction générale et au conseil d'administration.

7. Suivi et rapports

Des systèmes de surveillance et d'audit pour détecter le comportement illégal ou contraire à l'éthique et les lignes directes des employés devraient être utilisés. La meilleure approche consiste à coordonner plusieurs systèmes de surveillance et d'audit. Par exemple, le plan d'audit interne devrait recevoir des ressources appropriées et être appliqué à toutes les entreprises de l'organisation. En outre, il devrait inclure un examen du programme de conformité.

L'examen de la conformité examine (a) l'efficacité des documents écrits, (b) la réception des communications des employés, (c) le traitement des violations, (d) l'équité de la discipline, (e) le respect des protections accordées aux informateurs et (f) l'accomplissement des responsabilités de l'unité de conformité.

Les privilèges avocat-client et de l'avocat-travail-produit protègent certaines informations divulguées (ou produites par) à un avocat pour être utilisé par une partie adverse dans une instance judiciaire. Un avocat qui surveille la hotline est le mieux protégé des privilèges. Les employés peuvent avoir peu de confiance dans ces lignes directes ou dans des rapports d'écriture ou une personne hors site affectée pour entendre des plaintes. Mais ils peuvent avoir confiance en des lignes directes répondues par un représentant interne et soutenues par une politique de non-représailles. Cependant, une hotline ne peut pas garantir l'anonymat.

Un agent sur place peut être affecté pour recevoir et enquêter sur les plaintes. Cet individu (un médiateur) est plus efficace s'il (1) relève directement du responsable de la conformité ou du conseil, (2) garde le secret des informateurs, (3) fournit des conseils aux informateurs, et (4) effectue un suivi pour s'assurer que des représailles n'ont pas eu lieu.

Un questionnaire sur l'éthique doit être envoyé à chaque employé pour se demander si l'employé connaît des remboursements, des pots-de-vin ou d'autres actes répréhensibles.

Les normes de conformité organisationnelles devraient être appliquées de manière uniforme par une discipline adéquate, juste et spécifique à un cas. La punition doit être appropriée à l'infraction, comme un avertissement, une perte de salaire, une suspension, un transfert ou une résiliation. Le programme devrait prévoir la discipline des managers et d'autres personnes responsables qui connaissaient ou auraient dû savoir de l'inconduite et ne l'ont pas signalé. Le défaut de le faire indique un manque de diligence raisonnable. En conséquence, un tribunal peut déclarer que (1) le

programme n'est pas efficace et (2) l'organisation est donc légalement responsable d'accorder l'autorité aux personnes ayant tendance à commettre des crimes.

Le licenciement ou toute autre sanction des employés peut être limitée par (1) les lois sur les dénonciations ; (2) exceptions légales à la doctrine de l'employé-à-volonté (le droit d'un employeur de licencier un employé pour quelque raison que ce soit) ; (3) contrats d'employé ou d'union ; Et (4) les responsabilités de l'employeur en matière de discrimination, de décharge injustifiée et d'exigences pour agir de bonne foi. La sanction des employés devrait être bien documentée afin que l'organisation puisse prouver qu'elle a fait tout son possible pour collecter des informations et prendre les mesures appropriées.

Après la détection, la réponse devrait être appropriée et conçue pour prévenir d'autres infractions similaires. Dans certaines circonstances, une réponse appropriée peut exiger l'auto-déclaration des violations au gouvernement, la coopération avec les enquêtes et l'acceptation de la responsabilité. Un programme de conformité efficace et des réponses appropriées peuvent entraîner une peine plus indulgente pour avoir commis l'infraction. Le défaut de détecter ou de prévenir une violation grave peut indiquer que le programme de conformité doit être restructuré. Un changement qui peut être nécessaire est le remplacement ou le transfert du personnel de conformité.